Segurança de Dados

MCTA023-17

Introdução a Criptografia Moderna: Confidencialidade

Profª Denise Goya

Roteiro

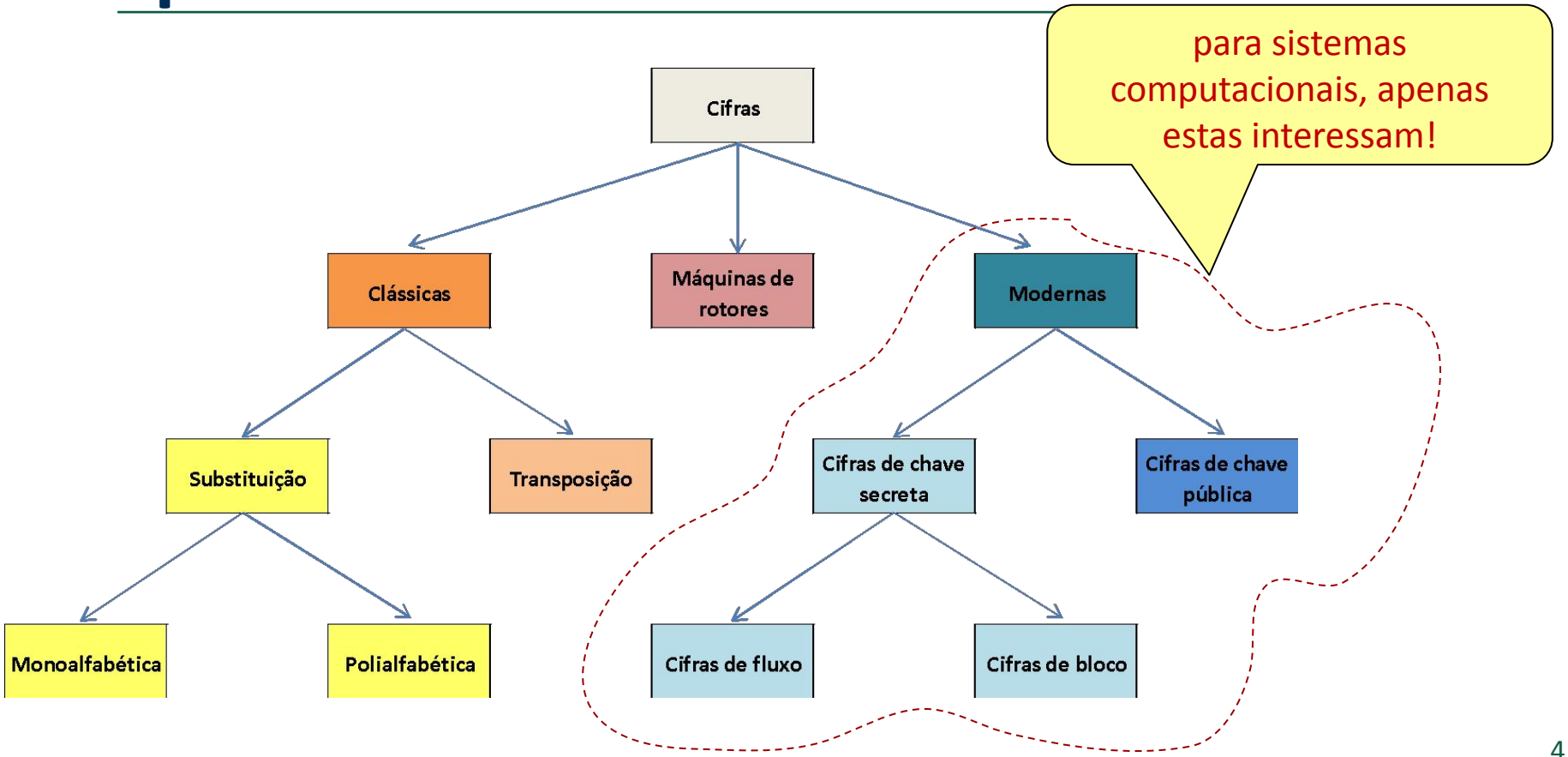
- Escolha dos Temas pra o trabalho em equipes

- Criptografia e Confidencialidade
  - cifras modernas e criptografia simétrica
    - princípios de construção
    - cifras de fluxo
    - cifras de bloco: DES, AES, modos de operação
- Noções de Segurança:
  - Sistema Computacionalmente Seguro versus
  - Segurança Incondicional

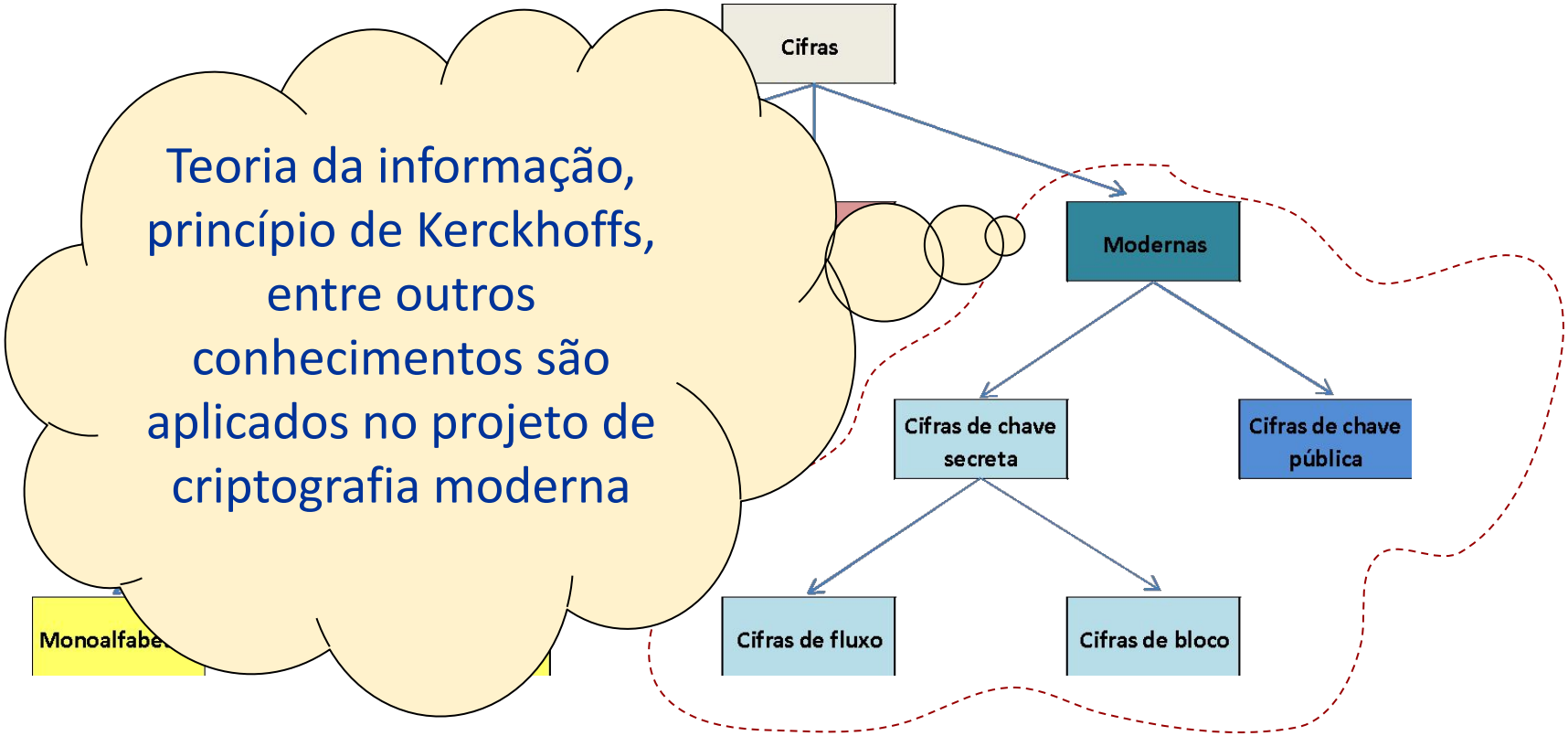
Trabalho em Equipes: Escolha dos Temas no Moodle

	Segurança de Dados - Temas e Equipes dos Trabalhos		Para editar, faça login UFABC no Google			
G1	**Software malicioso (G1)**		**Nome e Sobrenome**	**Situação**	**Turma**	**Contato**
	Tópicos obrigatórios:	1				
	Tipos e Funcionamento	2				
	Técnicas de Detecção e Defesas (estáticas e dinâmicas)	3				
	Referências principais:	4				
	Aslan, Ö. A. and Samet, R. "A Comprehensive Review on Malware Detection Approaches," in IEEE Access, vol. 8, pp. 6249-6271, 2020, doi: 10.1109/ACCESS.2019.2963724.	5				
	W. Stallings and L. Brown, Computer Security: Principles and Practice, 4ed.:Pearson Education, 2018.	.	.	.		.
		.	.	.		.
G2	**Ataques de negação de serviço (G2)**		**Nome e Sobrenome**	**Situação**	**Turma**	**Contato**
	Tópicos obrigatórios:	1				
	DoS e DDoS (Tipos e Funcionamento)	2				
	Técnicas de Prevenção e Detecção	3				
	Defesas e respostas contra DoS e DDoS	4				
	Referências principais:	5				
	Laufer, R. P., Moraes, I. M., Velloso, P. B., Bicudo, M. D., Campista, M. E. M., Cunha, D. d. O., Costa, L., and Duarte, O. (2005). Negação de serviço: Ataques e contramedidas. Livro Texto dos Mini-cursos do V Simpósio Brasileiro de Segurança da Informação e de Sistemas	.	.	.		.

Tipos de Cifras



Tipos de Cifras



Criptografia e Confidencialidade:

Criptografia Simétrica (de chave secreta)
e
Cifras Modernas

Criptografia Simétrica

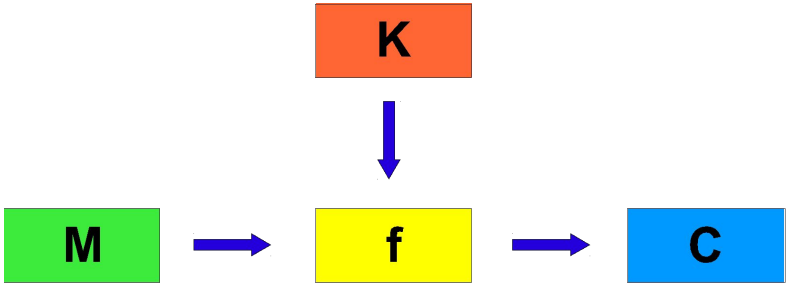
Criptografia de chave secreta

(ou criptografia simétrica):

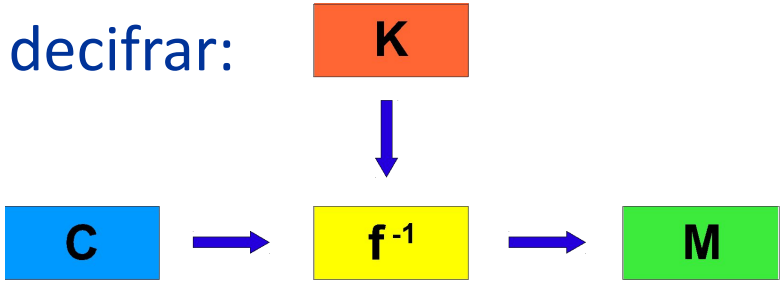
- Uma única chave secreta é usada para
  - cifrar e
  - decifrar

Criptografia Simétrica

Chave única para cifrar:



e para decifrar:



Criptografia Simétrica

Dois tipos:

- cifras de fluxo
- cifras de bloco

Cifras de Fluxo

- Opera sobre mensagens de qualquer tamanho
- O texto cifrado resultante tem o mesmo tamanho do texto original
- A chave tem tamanho fixo:
  - É necessário um procedimento de <u>expansão da chave</u> para cifrar mensagens de tamanho maior que a chave

Cifras de Fluxo

Exemplos:

- - cifra de Vigenère (cifra clássica, insegura)

- - One-time Pad (variante de Vernan)
- - RC-4 (SSL, WEP): passível de ataque
- - A5 (GSM): atacável em tempo real
- - outras recentes: ver ECrypt Stream Cipher Project (ww.ecrypt.eu.org/stream)

Cifras de Fluxo

Uso mais comum:

transmissões sem fio (fluxo contínuo com necessidade de sigilo):

- voz
- dados
- vídeo

Princípios de Construção

- Princípio de Kerckhoffs
  - algoritmos de domínio público, amplamente analisados por pesquisadores e estudiosos
  - Vulnerabilidades de projeto são documentadas
- Teoria da Informação
  - aumento de **entropia**: Confusão e Difusão
    - (baixa entropia implica redundância, que se traduz em padrões que podem ser explorados por criptanalista)

- (outros mais...)

Confusão

- Aparente falta de relação entre
  - mensagem (texto claro),
  - chave e
  - texto cifrado

- Obtida por **substituições** (polialfabéticas)
  - Como as realizadas na Enigma e em Vigenère

Difusão

- Dispersão da informação da **mensagem** e da **chave** por todo o texto cifrado
  - mensagem deve ser “embaralhada”
- Obtido por permutações e transposições
  - texto é distribuído em forma de matrizes que são transpostas, ou têm colunas permutadas
  - Ex: cifra ADFGVX (1ª Guerra)

Junção: Confusão e Difusão

Obrigatória a UNIÃO para a força

Confusão e Difusão devem ser usadas **conjuntamente** e de forma **iterada**, para fortalecer a cifra (aumentar entropia):

M → subst. → transp. → subst. → transp. → ...→ **C**

Mas só isso ainda não é suficiente!

- uso de computadores pode auxiliar na **criptanálise** de cifras

Visões de Segurança

1) **Segurança incondicional**

- Impossibilidade de decodificação, a menos que se conheça a chave: **one-time pad**

2) Cifra **computacionalmente segura**

– O custo para “quebrar” a cifra excede o valor da informação que foi cifrada

– O tempo necessário para “quebrar” a cifra excede o tempo de vida útil de uma informação

One-Time Pad (OTP)

- Única que satisfaz **Segurança incondicional** (segurança perfeita) de cifra: demonstrada por Shannon
  - mas na prática não é fácil usá-la de forma segura (dificuldades de implementação)

- A **chave** deve satisfazer (simultaneamente):
  - ser **verdadeiramente aleatória**
  - **nunca** ser usada mais de uma vez
  - ter pelo menos o **mesmo comprimento** da mensagem

One-Time Pad (OTP)

Cifrar:

$$C_i \leftarrow M_i \oplus K_i$$

ou exclusivo
(XOR)

Decifrar:

$$M_i \leftarrow C_i \oplus K_i$$

Note que equivale à cifra de Vigenère com n=2 (bits 0 e 1 compõem o alfabeto)

XOR: ou exclusivo

A	B	A XOR B
0	0	0
0	1	1
1	0	1
1	1	0

Releitura do XOR:

- XOR bits iguais ⇒ zero
- XOR bits diferentes ⇒ um
- Zero XOR ♠ ⇒ ♠

RC-4

- Desenvolvido por Rivest em 1987
- Amplamente adotado
  - ex: WEP, opção de cifra no SSL, Kerberos
- **Fraqueza**: núcleo do algoritmo inclui ideia do One-time Pad, mas se uma mesma chave for usada repetidas vezes tem-se um sistema inseguro

RC-4

Problema em repetir uma chave:

$$\left.\begin{array}{rcl} C_i & = & M_i \oplus k_i \\ C_i^* & = & M_i^* \oplus k_i \end{array}\right\} \Rightarrow C_i \oplus C_i^* = M_i \oplus M_i^*$$

Independe da chave!

Basta o comprometimento de uma única mensagem M, para se comprometer todas as outras M* que foram cifradas com a mesma chave:

$$M^* = M \oplus C \oplus C^*$$

Ataque de texto claro conhecido, *known-plaintext attack*

Cifras de Fluxo

Problema em repetir uma chave (vale para outras cifras):

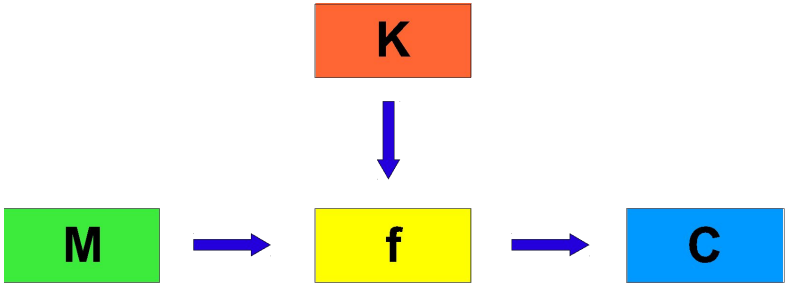
- recorrente em várias cifras de fluxo
- o **problema está no uso** (aplicação do algoritmo) e não no algoritmo em si
- Dificuldade de desenvolvimento de projeto robusto de cifra de fluxo:
  - que reduza problemas de uso indevido
  - **área de pesquisa ativa**

Criptografia e Confidencialidade:

Cifras de Bloco

Cifras de Bloco

- Opera sobre mensagens de tamanho fixo
- A chave tem tamanho fixo (em geral, mesmo tamanho do bloco)



Cifras de Bloco

Exemplos:

- DES e 3DES (padrão de 1977 a 2002)
- AES (padrão atual, a partir de 2000)

Cifras de Bloco: DES

DES (Data Encryption Standard):

- padrão do governo dos EUA em 1977
- bloco de 64 bits
- chave de 56 bits
- função de Feistel:
  - mistura **bits** de dado com chave
  - realiza substituições e permutações
  - é iterada 16 vezes
  - a cada iteração só 48 bits da chave inicial são usados

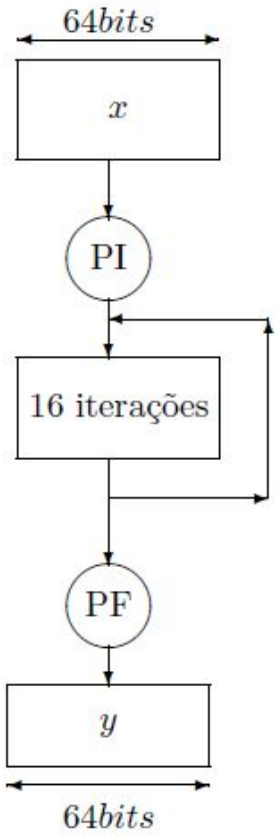
DES: Estrutura Geral

entrada: mensagem **x** de 64 bits

processamento:

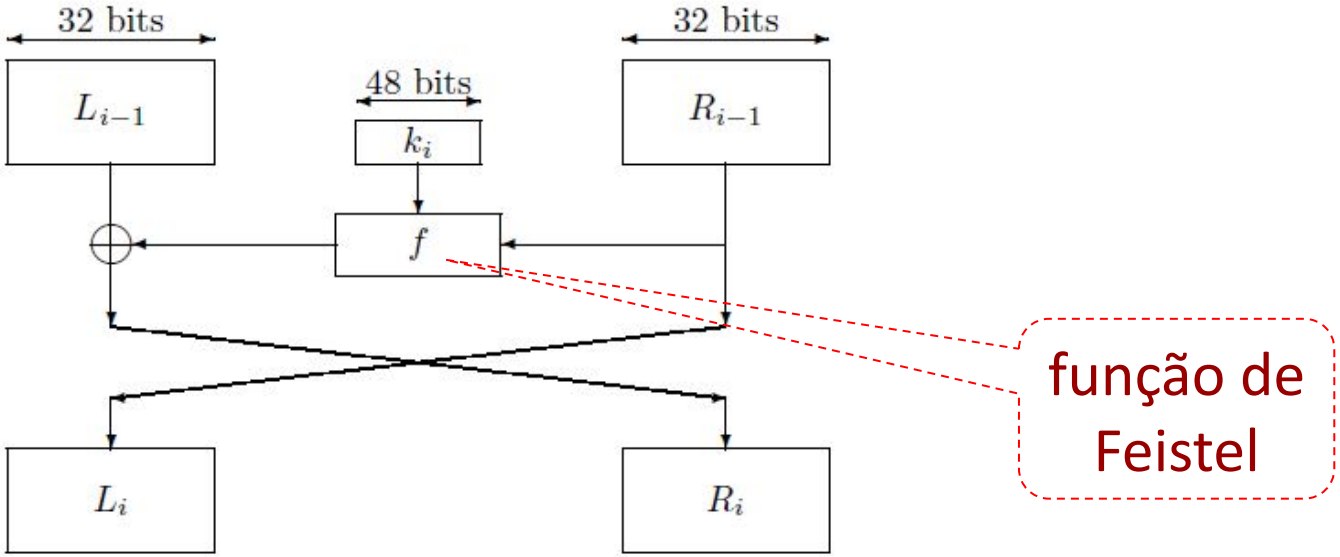
- x passa por uma permutação inicial (PI)
- resultado é iterado 16 vezes numa estrutura de Feistel
- resultado passa por uma permutação final (PF), gerando **y**

saída: texto cifrado **y** de 64 bits

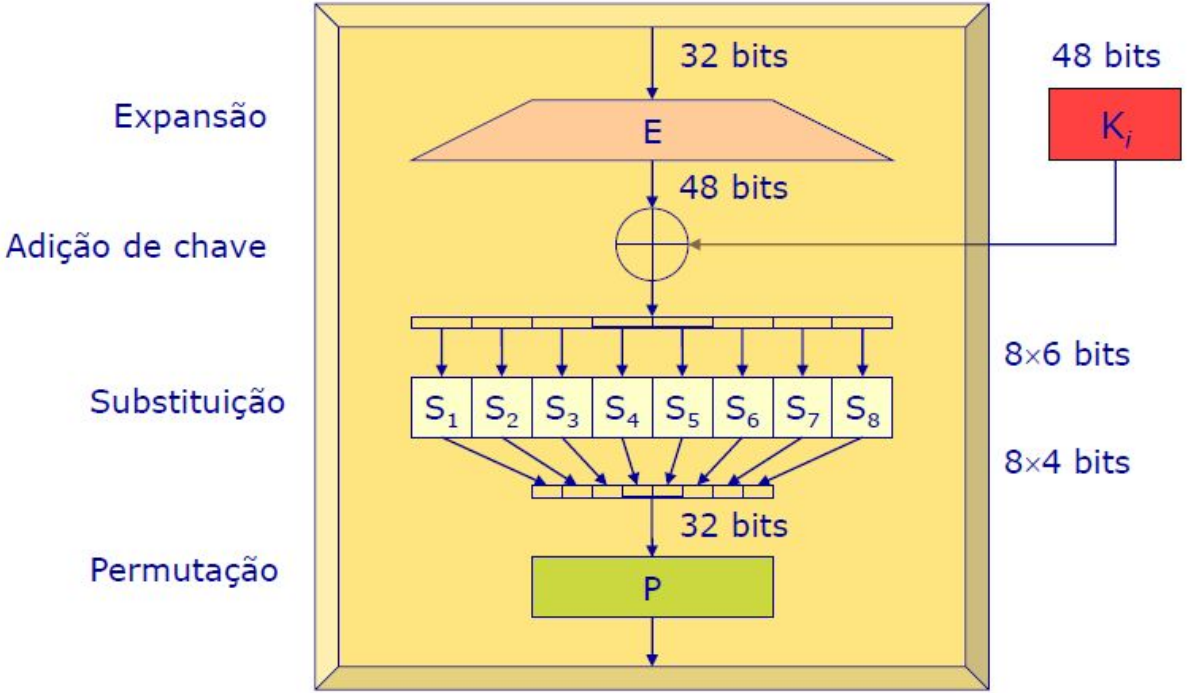


DES: Estrutura de Feistel

Cada iteração processa o fluxo em duas metades, combinando uma das metades com parte da chave (expansão de chave, substituição e permutação)



DES: Função *f* de Feistel



A função de Feistel possui 4 etapas:

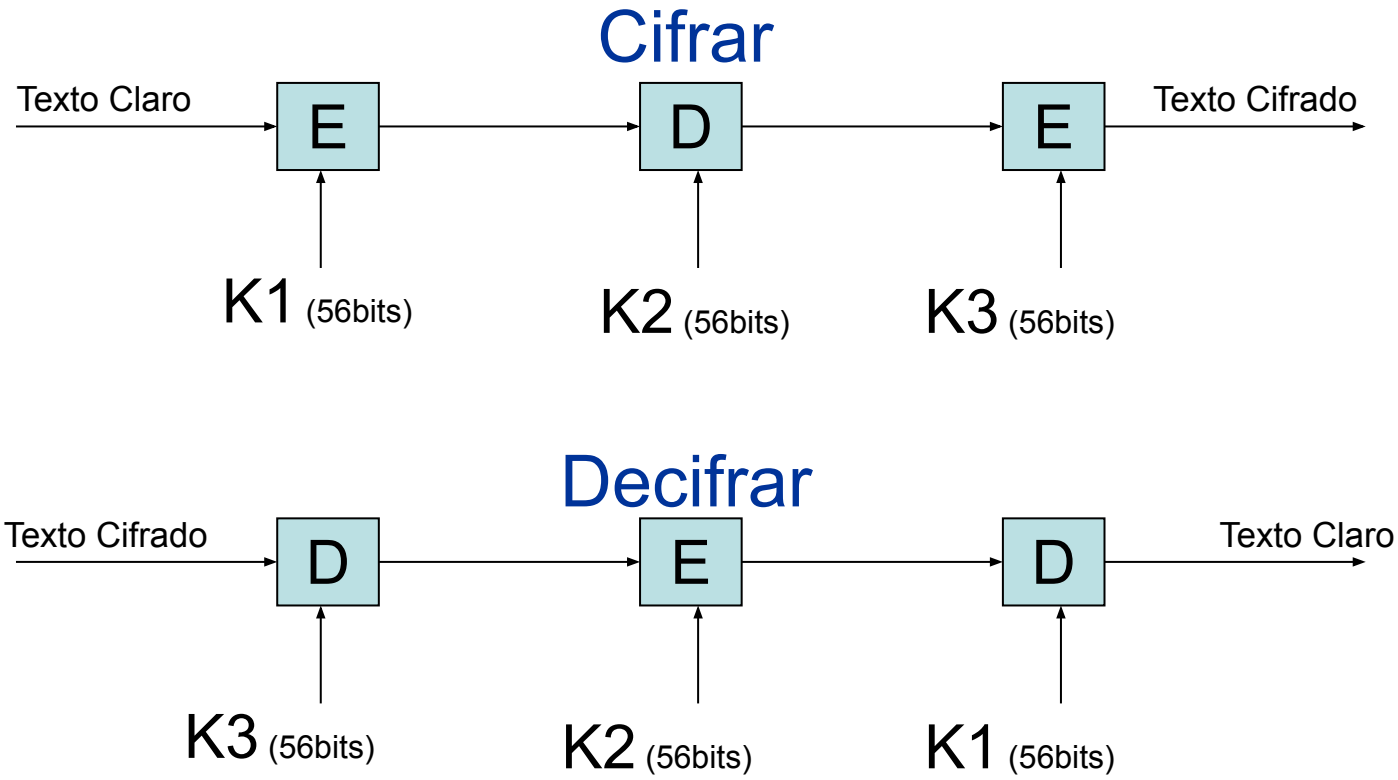
- Expansão de chave de 32 bits para 48
- Adição de chave, por meio de xor
- Substituição e recodificação para 32 bits
- Permutação dos bits

DES: em Desuso

Chave de 56 bits:

- bom na época do projeto
- não resiste a força bruta com capacidade computacional de hoje
- alternativa (sobrevida ao DES até 2000): **3DES**
  - aplicação do DES três vezes (cifra, decifra, cifra)
  - uso de 3 chaves diferentes, de 56 bits cada (K1, K2 e K3)

3DES


Cifrar
Texto Claro
E
D
E
Texto Cifrado
K1 (56bits)
K2 (56bits)
K3 (56bits)
Decifrar
Texto Cifrado
D
E
D
Texto Claro
K3 (56bits)
K2 (56bits)
K1 (56bits)

DES: Problemas Estruturais

Criptanálise diferencial (1980)

Criptanálise linear (1993)

e outros métodos derivados:

- por análises estatísticas, é possível encontrar viés que fornece indícios de valor para alguns **bits da chave**

- mesmo 3DES é obsoleto (inseguro)

Cifras de Bloco: Novo Padrão

AES (Advanced Encryption Standard)

Cifras de Bloco: AES

AES (Advanced Encryption Standard):

- concurso público promovido pelo NIST seleciona novo padrão nos EUA em 2000
  - vencedor: algoritmo **Rijndael** (Daemen e Rijmen)
- resistente a ataques de criptanálise elementares
- eficientemente implementável em hardware e software

AES: Rijndael

AES é um subconjunto do Rijndael:

- usa blocos de mensagens de tamanho fixo (128 bits)
- usa chaves de 128 bits (10 iterações), 192 bits (12 iterações) ou 256 bits (14 iterações)

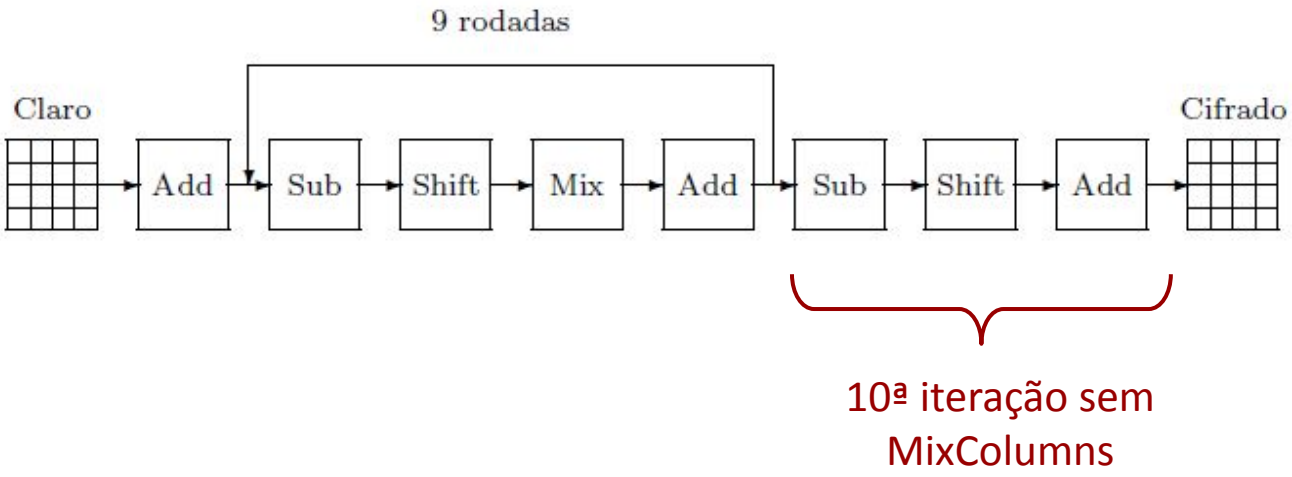
Rijndael original usa blocos de mensagens e chaves variáveis de 128 a 256 bits, expandidos em múltiplos de 32 bits.

AES: Rijndael

- AES também executa várias iterações e gera subchaves
- Dados e chave em matriz 4x4 de bytes
- Quatro transformações:
  - AddRoundKey — mistura dado e chave;
  - SubBytes — **substituição** não-linear;
  - ShiftRows — transposição de bytes (**difusão** entre as colunas de dados);
  - MixColumns — multiplicação da matriz por um polinômio (**difusão** dentro de cada coluna)

AES: Estrutura Geral

AES de 128 bits (16 bytes):

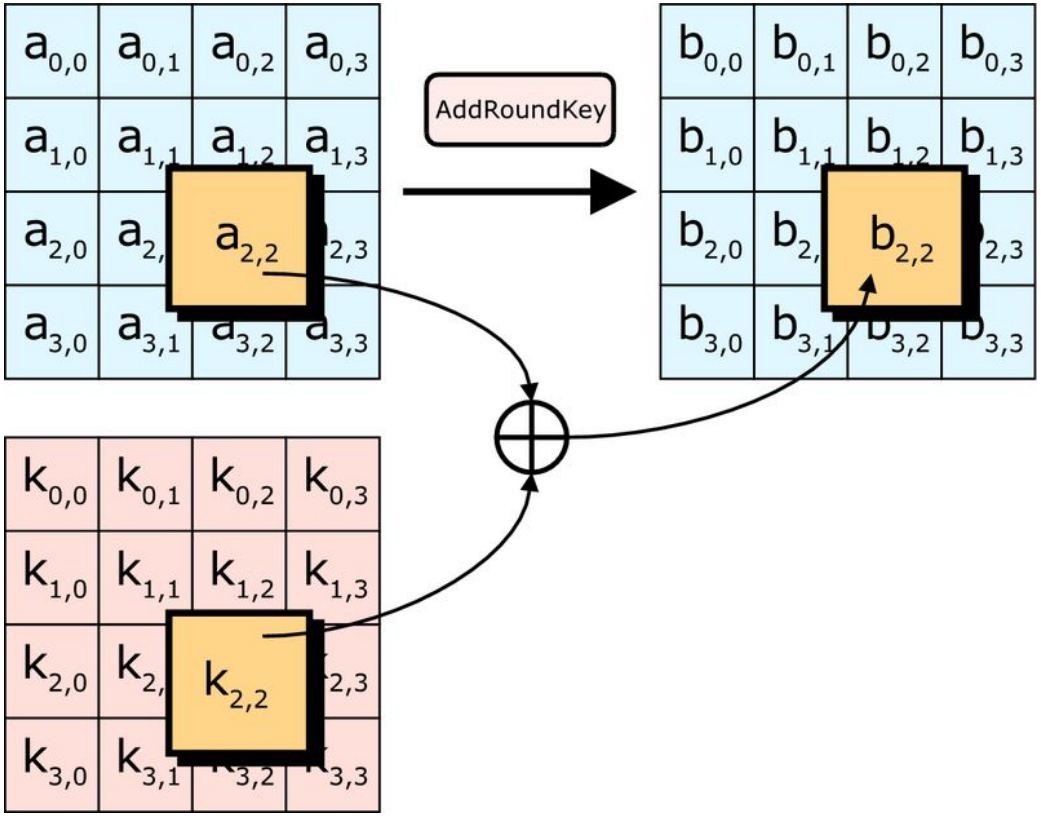


Entram 128 bits de mensagem que são dispostos em uma matriz de 4 x 4 bytes

Operações *Add, Sub, Shift* e *Mix* são iteradas 10 vezes

Sai o texto cifrado em uma matriz de 128 bits, 4x4

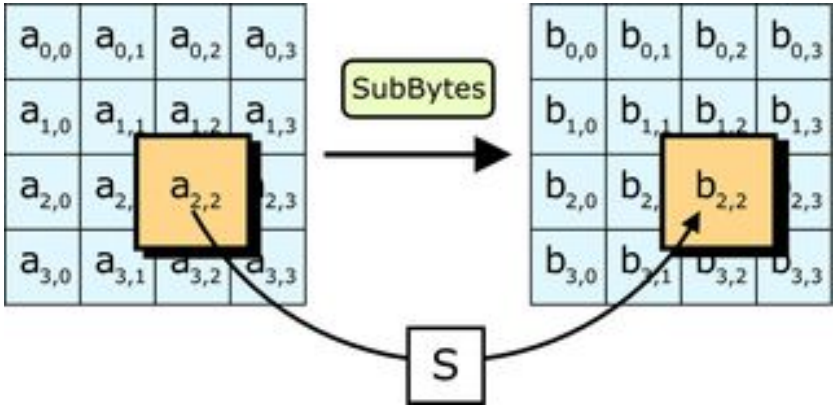
AES: AddRoundKey

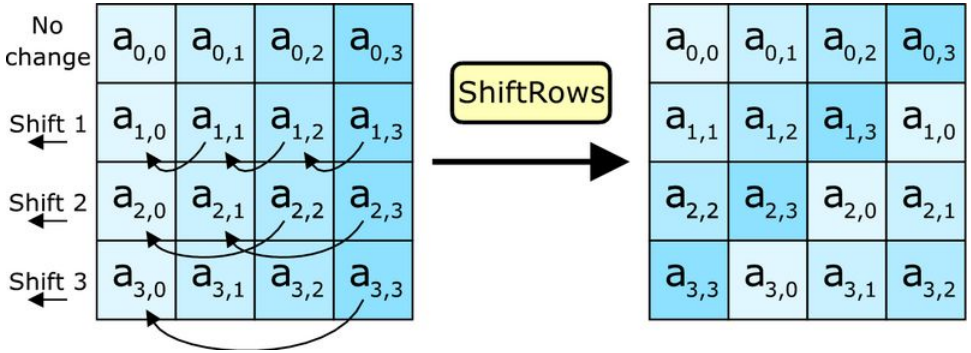


Operação *Add* faz o ou exclusivo de duas matrizes 4 x 4 bytes:

mensagem XOR chave

AES: SubBytes e ShiftRows

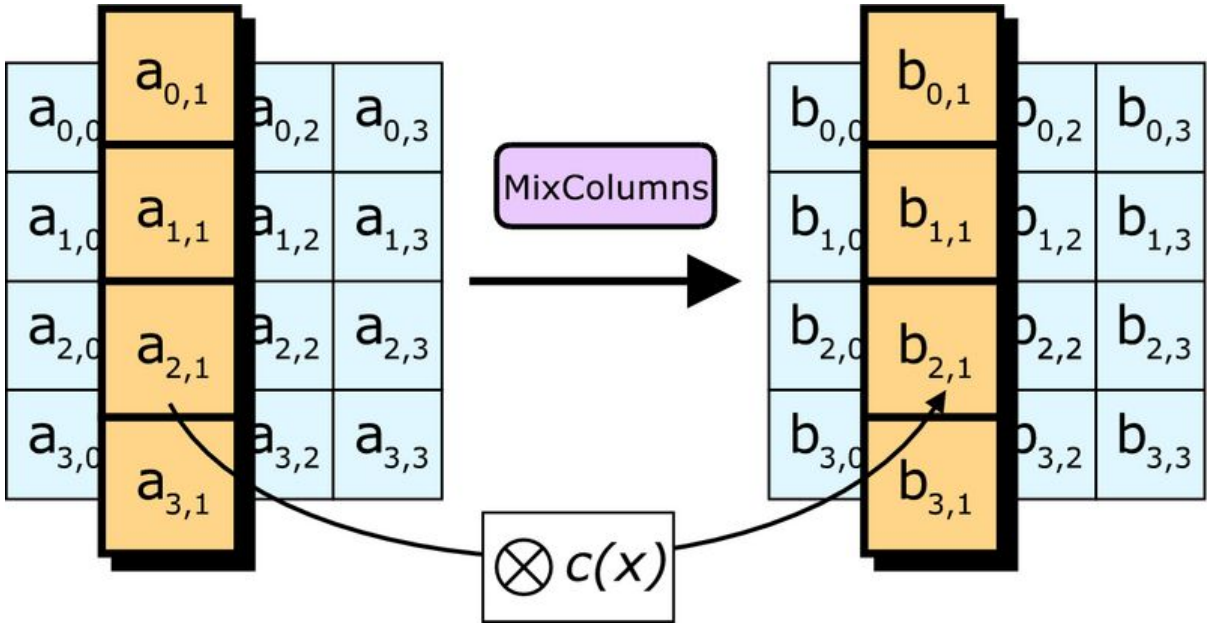




Operação *SubBytes* substitui um byte por outro (substituição polialfabética não linear)

Operação *ShiftRows* realiza transposições por meio de deslocamentos das linhas da matriz

AES: MixColumns



MixColumns aplica uma operação coluna a coluna matriz

Outros Padrões

Europeu

- NESSIE (New European Schemes for Signatures, Integrity and Encryption):
  - vários algoritmos para cifragem foram selecionados (MISTY1, Camellia, SHACAL-2, além do AES);

Japonês

- CRYPTREC (Cryptography Research and Evaluation Committee)

Criptografia e Confidencialidade:

Modos de Operação

Modos de Operação de Cifras de Bloco

Cifras de bloco apenas operam sobre mensagens de **tamanhos fixo**

Modo de operação: extensão para outros tamanhos de mensagem

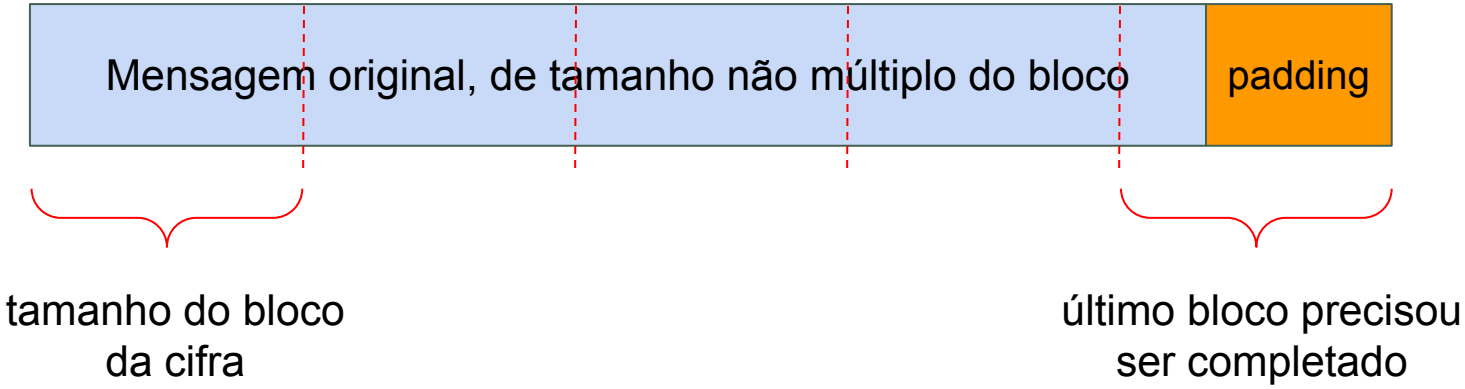
Modos para confidencialidade:

- **ECB, CBC** (padding)
- **CFB, OFB**, CTR
- LRW, XEX, EME (cifração setorial)

Padding

Preenchimento da mensagem para que o comprimento seja múltiplo do tamanho do bloco.

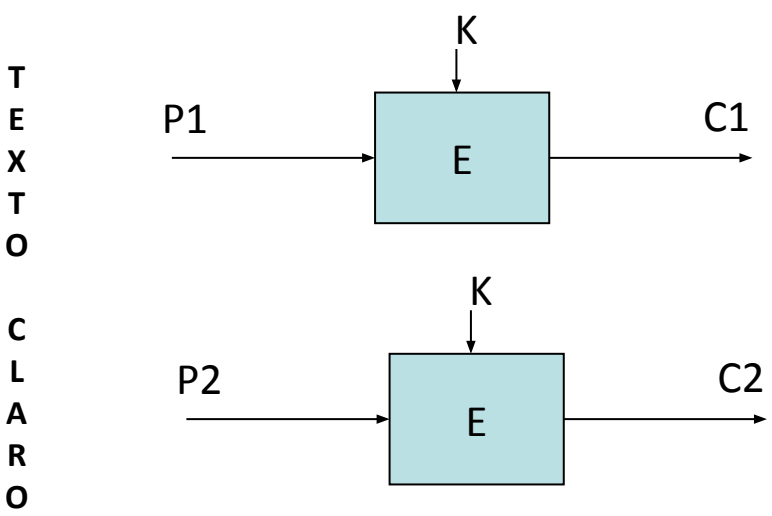
Usado em modos de operação como **ECB, CBC**

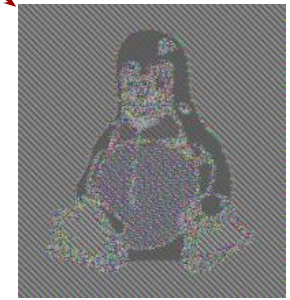


Electronic Code Book (ECB)

Aplicação direta do método criptográfico em cada bloco de mensagem.

Modo muito vulnerável, principalmente para imagens (arquivos grandes)





Fonte: https://pt.wikipedia.org/wiki/Modo_de_opera%C3%A7%C3%A3o_(criptografia)

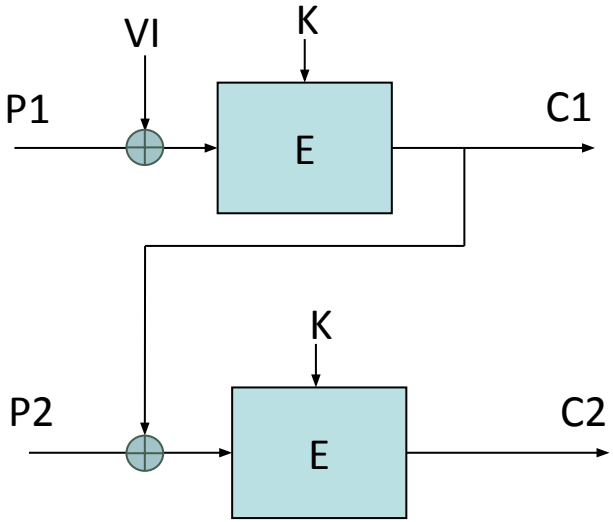
Cipher Block Chain (CBC)

Modo de encadeamento de blocos de cifra

Cada bloco de mensagem passa por um XOR (ou exclusivo) com o texto cifrado do bloco anterior.

No primeiro bloco o XOR ocorre com um Vetor de Inicialização (VI)

Propaga erros (não dá para ser usado em canais com ruído)



Cipher Feedback (CFB)

Existem aplicações que não podem esperar que o primeiro bloco de mensagem seja completamente lido para iniciar o processo de cifragem.

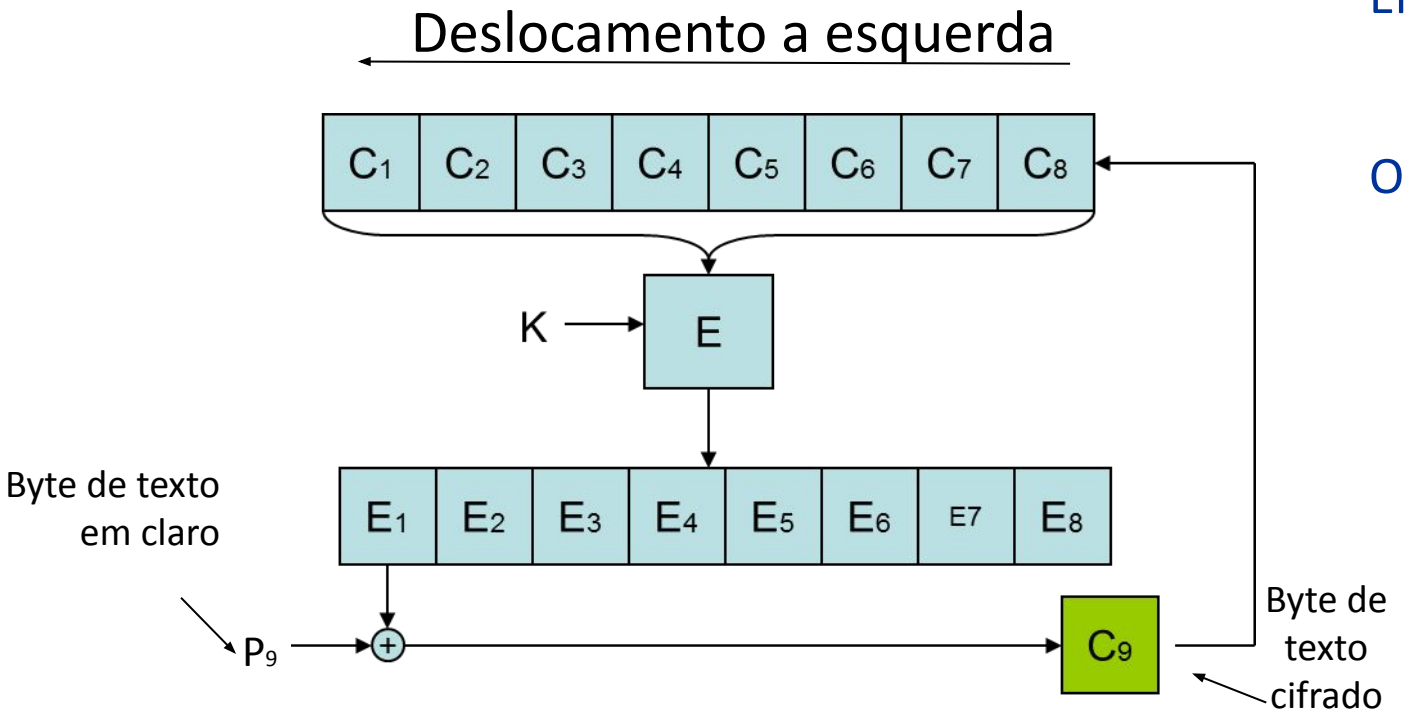
Exemplo: Aplicação de sessão de terminais (SSH)

Cipher Feedback :

Permite que a **cifragem** seja feita **byte a byte**

Também propaga erros

Cipher Feedback



Ex. de funcionamento:

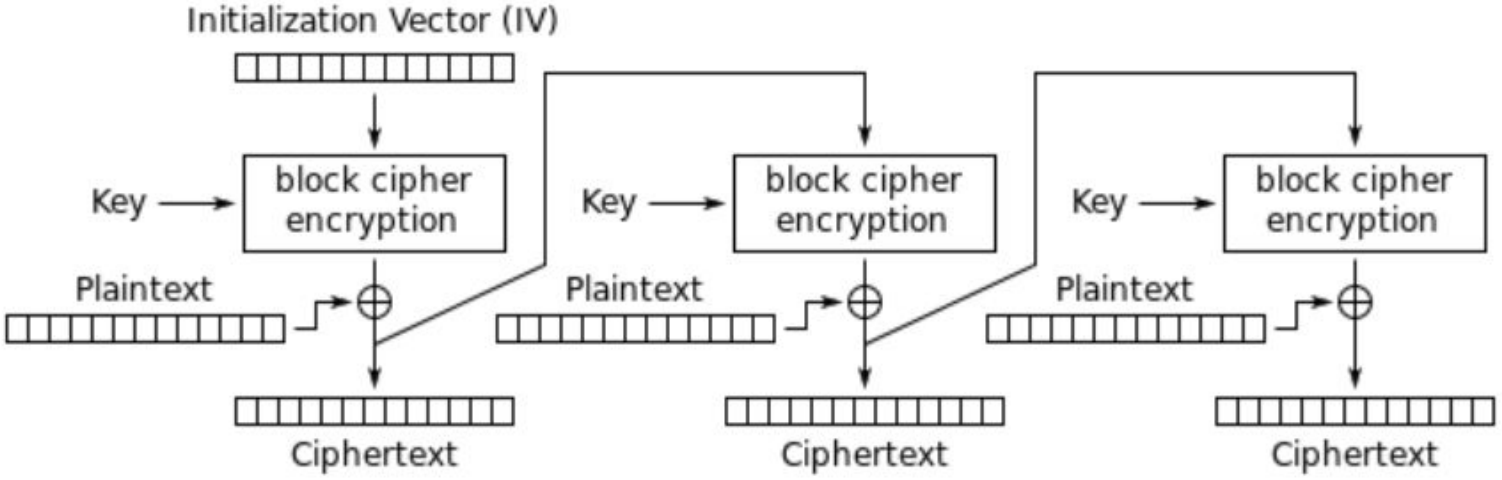
Entram 8 bytes e o algoritmo gera 8 bytes cifrados

O primeiro byte de saída XOR próximo byte da mensagem é transmitido e, em seguida, anexado aos 8 bytes de entrada anterior (com deslocamento à esquerda): CFB-8

Cipher Feedback: visão das iterações

$$C_i = \begin{cases} \mathrm{IV}, & i = 0 \\ E_K(C_{i-1}) \oplus P_i, & \text{otherwise} \end{cases}$$

$$P_i = E_K(C_{i-1}) \oplus C_i,$$



Fonte: https://en.wikipedia.org/wiki/Block_cipher_mode_of_operation

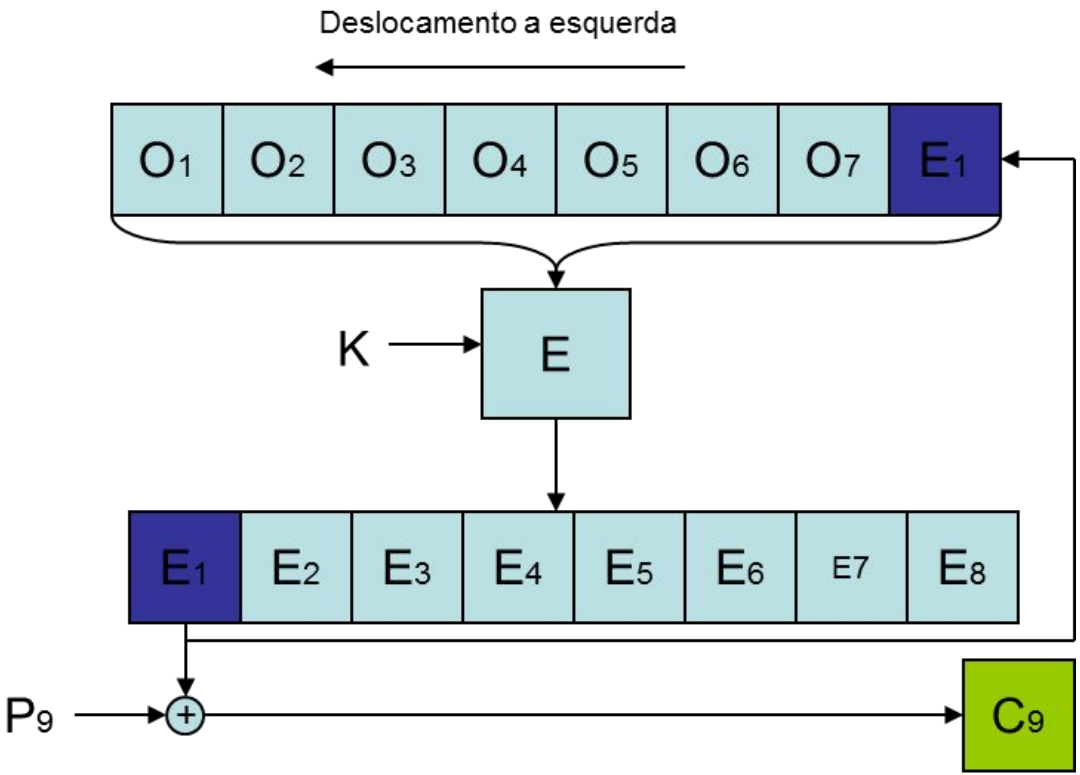
Output Feedback (OFB)

Equivalente ao anterior, mas em vez de se utilizar o texto em claro utiliza-se a saída da cifragem para incrementar o registro de deslocamento.

Não propaga erros para o próximo bloco.

Podem ser usados códigos de correção de erros.

Output Feedback (OFB)



Ex. de funcionamento:

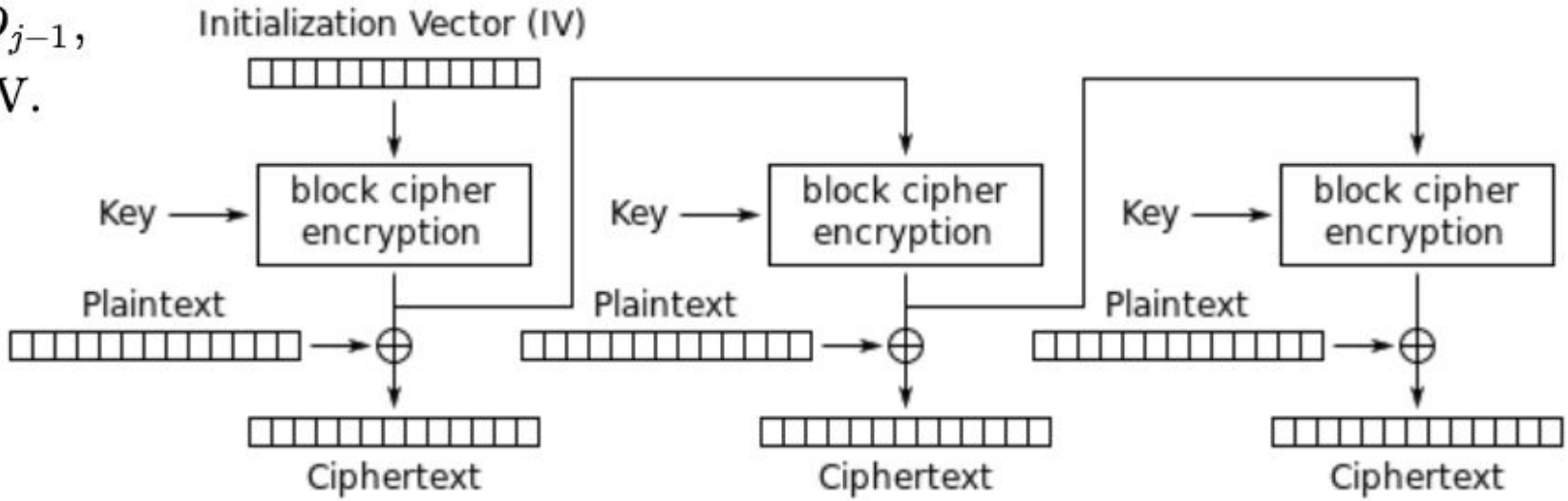
Entram 8 bytes e o algoritmo gera 8 bytes cifrados

O primeiro byte de saída é anexado aos 8 bytes de entrada anterior (com deslocamento à esquerda)

É transmitido o primeiro byte XOR próximo byte da mensagem

Output Feedback: visão das iterações

$$C_j = P_j \oplus O_j,$$
$$P_j = C_j \oplus O_j,$$
$$O_j = E_K(I_j),$$
$$I_j = O_{j-1},$$
$$I_0 = \mathrm{IV}.$$



Fonte: https://en.wikipedia.org/wiki/Block_cipher_mode_of_operation

Próxima Aula

Laboratório: criptanálise de frequência de caracteres e preparo da máquina virtual

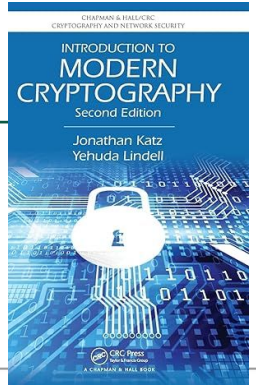
Próxima aula de Teoria:

- Criptografia e Integridade
- Criptografia Assimétrica
  - Confidencialidade
  - Integridade
  - Autenticidade
  - Irretratabilidade

Estudo Individual

Leituras Sugeridas

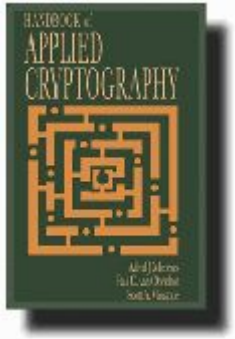
- Jonathan Katz, Yehuda Lindell. Introduction to Modern Cryptography, Second Edition. CRC Press. 2014.
- Jerônimo C. Pellegrini, Introdução a Criptografia e seus Fundamentos - Notas de aula - versão preliminar, Capítulo 5. (2019), disponível em http://aleph0.info/cursos/ic/notas/
- Alfred J. Menezes, Paul C. van Oorschot and Scott A. Vanstone, Handbook of Applied Cryptography, Capítulo 6. CRC Press (1996), disponível em http://cacr.uwaterloo.ca/hac/



Introdução à Criptografia e seus Fundamentos
notas de aula – versão: 2019.11.28.20.34

Jerônimo C. Pellegrini

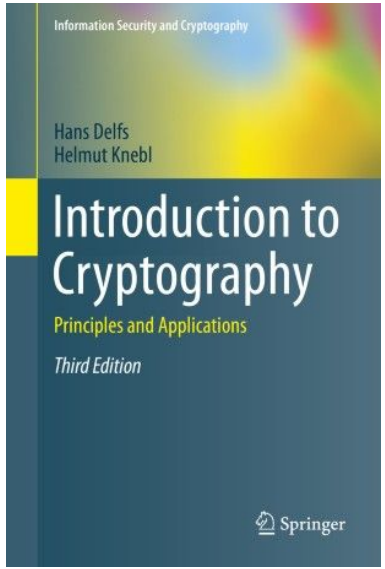
id: e052a0bf8a7589c0c522c6b66cd88eb23b67d1b9
compilado em: 29 de novembro de 2019



Outras Leituras

Tutorial para acesso a Livros via Cafe Capes, com login institucional UFABC:

https://portal.biblioteca.ufabc.edu.br/images/docs/Orientacoes_para_o_acesso_remoto_via_CAFe.pdf



Logado, acesse:

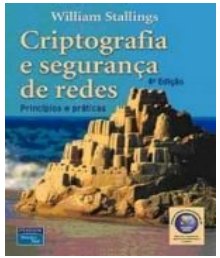
https://link-springer-com.ez42.periodicos.capes.gov.br/book/10.1007/978-3-662-47974-2

e leia Capítulo 2 de

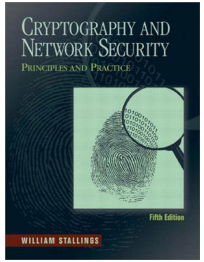
Hans Delfs, Helmut Knebl. Introduction to Cryptography Principles and Applications, Springer (2015)

Outras Leituras

- Stallings, W. Criptografia e segurança de redes – Princípios e Práticas, 4 edição, ed Prentice Hall.



- Stallings, W. Cryptography and Network Security: Principles and Practice, 5.ed. Prentice Hall.



Questões de Autoavaliação

(não precisa entregar)

Exercícios: One-Time Pad

Considere a codificação de caracteres em binário dada na tabela ao lado. Elimine acentos e espaços em branco das mensagens.

Binário	Símbolo	Binário	Símbolo
00000	@	10000	P
00001	A	10001	Q
00010	B	10010	R
00011	C	10011	S
00100	D	10100	T
00101	E	10101	U
00110	F	10110	V
00111	G	10111	W
01000	H	11000	X
01001	I	11001	Y
01010	J	11010	Z
01011	K	11011	[
01100	L	11100	\
01101	M	11101	]
01110	N	11110	^
01111	O	11111	_

1- Cifre seu nome, usando a chave

k = JSUEMCIOHZEJF]XASMCOKWPHHAF\CGBPLVSFDRCAMBQL@

2- Decifre uma cifra gerada por seu colega

Tabela-Verdade para OU-EXCLUSIVO		
Entrada 1	Entrada 2	Saída
0	0	0
0	1	1
1	0	1
1	1	0

Exercícios

3- Suponha que o exercício sobre One-Time Pad fosse repetido usando-se a tabela ASCII (de 7 ou 8 bits). Qual texto cifrado lhe parece mais seguro e por quê: o proveniente da tabela de 5 bits ou o da tabela padronizada?

4- Pesquise os motivos pelos quais existe o 3DES, mas não um “2DES”, em que são usadas duas aplicações do DES original, com duas chaves.